

# NSE – Nmap Scripting Engine

Categorías de scripts y uso en pentesting

14 categorías • Lua • Referencia rápida 2025

**Que es NSE:** el motor de scripting de nmap escrito en Lua. Permite extender nmap con scripts que automatizan reconocimiento, detección de vulnerabilidades, brute force y explotación. Cada script pertenece a una o mas categorías que definen su agresividad y uso. Ubicación: `/usr/share/nmap/scripts/`

## 1. Tabla de categorías

| Categoría        | Agresividad | Auto     | Función                                | Ejemplos                      |
|------------------|-------------|----------|----------------------------------------|-------------------------------|
| <b>default</b>   | Baja        | -sC / -A | Escaneo general util y seguro          | http-title, banner, ssl-cert  |
| <b>safe</b>      | Nula        | No       | Info sin ningun riesgo                 | banner, dns-nsid              |
| <b>auth</b>      | Baja        | No       | Credenciales por defecto               | ftp-anon, http-auth           |
| <b>discovery</b> | Baja        | No       | Reconocimiento de red y servicios      | dns-brute, snmp-info          |
| <b>version</b>   | Baja        | Con -sV  | Detectar versiones de servicios        | banner-plus                   |
| <b>broadcast</b> | Nula        | No       | Descubrir hosts sin IP objetivo        | broadcast-dhcp-discover       |
| <b>external</b>  | Baja        | No       | Consultar APIs externas (WHOIS, geo)   | whois-domain, shodan-api      |
| <b>intrusive</b> | Media       | No       | Enumeración agresiva, genera logs      | http-enum, smb-enum-users     |
| <b>malware</b>   | Baja        | No       | Detectar backdoors y compromiso        | ftp-vsftpd-backdoor           |
| <b>vuln</b>      | Media       | No       | Detectar CVEs sin explotar             | smb-vuln-ms17-010, heartbleed |
| <b>brute</b>     | Alta        | No       | Fuerza bruta con diccionarios          | ssh-brute, ftp-brute          |
| <b>fuzzer</b>    | Alta        | No       | Enviar datos malformados (crashes)     | dns-fuzz                      |
| <b>exploit</b>   | Maxima      | NUNCA    | Explotación activa de vulnerabilidades | http-shellshock               |
| <b>dos</b>       | Maxima      | NUNCA    | Denegación de servicio                 | http-slowloris                |

## 2. Categorías seguras

**default** – se ejecuta con `-sC` o `-A`. Son scripts rápidos, no intrusivos y útiles en la mayoría de casos. Todo script de default es también safe.

**safe** – no crashan servicios, generan mínimo tráfico. Pueden ejecutarse en producción sin riesgo.

**auth** – prueba credenciales triviales: anonymous, admin/admin, root sin password. No itera diccionarios (eso es brute).

**version** – se activan internamente con `-sV` cuando nmap no puede identificar el servicio con sus pruebas normales.

**broadcast** – no necesitan objetivo. Envían broadcast/multicast y escuchan quien responde. Útil al entrar a una red desconocida.

## 3. Categorías de reconocimiento

**discovery** – va más allá del puerto: consulta DNS, SNMP, LDAP, NFS. Recopila información activamente sin explotar nada.

**external** – consulta servicios de terceros en internet (WHOIS, VirusTotal, Shodan, geolocalización). Cuidado: envía datos del objetivo a servidores externos.

**malware** – busca indicadores de compromiso: back-

doors conocidos, puertos inusuales, firmas de malware. Útil en respuesta a incidentes.

## 4. Categorías agresivas

**intrusive** – generan mucho tráfico, aparecen en logs, pueden desestabilizar servicios frágiles. Nunca en producción sin permiso.

**brute** – fuerza bruta con diccionarios completos. Puede tardar horas y generar miles de intentos de login fallidos en los logs.

**fuzzer** – envían inputs malformados para provocar crashes o comportamientos anómalos. Pueden tumbar servicios.

## 5. Categorías peligrosas

**vuln** – detecta vulnerabilidades conocidas (CVEs) verificando si el servicio es vulnerable. No explota, solo informa. La más usada en pentesting.

**exploit** – va un paso más allá de vuln: explota activamente la vulnerabilidad. Puede dar shell, leer archivos, ejecutar comandos.

**dos** – prueba resistencia a ataques de denegación de servicio. Puede tumbar servicios reales. Jamás en producción.

## 6. Comandos de uso

```
# Escaneo estandar (default + version)
sudo nmap -sC -sV 192.168.1.1

# Solo scripts seguros
sudo nmap --script safe 192.168.1.1

# Buscar vulnerabilidades
sudo nmap --script vuln 192.168.1.1

# Combinacion de categorias
sudo nmap --script "auth or vuln or malware" 192.168.1.1

# Excluir categorias peligrosas
sudo nmap --script "not dos and not exploit and not brute" 192.168.1.1

# Scripts por patron (todos los de HTTP)
sudo nmap --script "http-*" -p 80,443 192.168.1.1

# Scripts por patron (todas las vulns SMB)
sudo nmap --script "smb-vuln-*" -p 445 192.168.1.1

# Script especifico con argumentos
sudo nmap --script ssh-brute --script-args userdb=users.txt,passdb=pass.txt 192.168.1.1

# Ver info de un script
nmap --script-help smb-vuln-ms17-010
```

## 7. Flujo tipico en pentesting

| Fase                | Categoria                   | Objetivo                                  |
|---------------------|-----------------------------|-------------------------------------------|
| 1. Descubrimiento   | <b>broadcast, discovery</b> | Que hosts y servicios existen             |
| 2. Enumeracion      | <b>default, safe, auth</b>  | Que versiones, banners, configuraciones   |
| 3. Vulnerabilidades | <b>vuln, malware</b>        | Que CVEs o backdoors hay                  |
| 4. Explotacion      | <b>exploit</b>              | Ganar acceso (con permiso)                |
| 5. Post-explotacion | <b>brute, intrusive</b>     | Escalar privilegios, moverse lateralmente |

**Aviso legal:** ejecutar scripts de las categorías **exploit**, **dos** o **brute** contra sistemas sin autorización expresa es ilegal en la mayoría de jurisdicciones. Usar siempre en laboratorio propio o con contrato de pentest firmado.